CLASSROOM BRIEFING

WHEN THE LOCK IS A PERSON

Five real breaches, told as they unfolded.



PROJECT TEAM

THE PRESENTER



DEVANSH JANI

Enrollment: 241105060055

THREE TRICKS. ORDINARY NAMES.

PHISHING

Routine message hides malicious payload.

PRETEXTING

Fabricated story exploits helpful human trust.

BAITING

Tempting offer weaponizes human curiosity.



CASE 01: INDIA

COSMOS BANK PUNE

Attackers breached the ATM switch, creating a fake approval desk that bypassed the core banking system to authorize fraudulent transactions globally.

- **Rs 94 Crore:** Lost in seven hours.
- **12,000+ ATMs:** Coordinated global withdrawal.
- **Proxy Switch:** Bypassed core banking system.
- **The Flaw:** Switch lacked secondary core verification.

Page A — Background and Attack Method

Introduction. The Cosmos Bank Pune incident is a useful case study for understanding how attackers can target financial systems and exploit weaknesses in payment infrastructure. The original presentation highlights a major loss, coordinated activity and a switch-related weakness. The lesson is that a bank’s security depends not only on customer passwords but also on the safety of internal systems, payment networks and operational controls.

How a banking cyberattack can work. In a payment-system attack, criminals may compromise a server or payment-processing component and then send unauthorized transaction instructions. Attackers may also attempt to misuse payment-card systems or international payment channels. If transaction authorization, monitoring or reconciliation controls are weak, fraudulent transactions may be processed before staff detect the activity.

Why payment switches matter. A switch routes transaction messages between banking systems, ATMs, card networks and other participants. It must validate requests, enforce limits and maintain reliable records. A compromised or misconfigured switch can create risk across multiple services, which is why it should be isolated, patched, monitored and protected with strict access controls.

Key points

- Use network segmentation so payment systems are separated from ordinary office networks.
- Require strong authentication and limited administrator privileges for critical systems.
- Monitor unusual transaction volumes, destinations, timing and repeated failed requests.
- Reconcile transaction logs with settlement records and investigate differences quickly.

Page B — Impact, Prevention and Lessons

Possible impact. A banking-system compromise can cause direct financial loss, service disruption, customer anxiety, investigation costs and reputational damage. Recovery may require disabling affected services, validating transaction records, coordinating with payment partners and notifying the appropriate authorities. A response must balance rapid containment with accurate evidence preservation.

Prevention and detection. Financial institutions should use layered security: secure configurations, timely updates, endpoint protection, network monitoring, multi-person approval for high-risk changes and independent review of transaction activity. Critical payment infrastructure should have tamper-resistant logs and alerting that cannot easily be disabled by the same account that operates the system.

Incident response. When suspicious activity is identified, responders should isolate affected components where safe, preserve logs and forensic evidence, involve the bank's security and payment teams, and verify transactions with trusted records. Systems should only be restored after the root cause is understood and controls have been tested.

Conclusion. The main lesson is that cyber resilience requires both technology and disciplined procedures. No single firewall or antivirus product can replace access control, monitoring, independent checks and a practiced incident-response plan.

Key points

- Keep backups of configurations and logs in protected, separate storage.
- Test incident-response plans with realistic exercises and clear escalation roles.
- Apply dual approval and transaction limits to unusual or high-value activity.
- Review third-party connections and payment-system access regularly.

CASE 02: INDIA

AIIMS NEW DELHI

Ransomware infected the primary hospital network due to weak internal segmentation, forcing one of India's largest medical institutes to revert to manual paper records.

- **Ransomware:** e-Hospital servers encrypted.
- **Soft Perimeter:** Unmanaged switches exploited.
- **Paper Shift:** Manual records for two weeks.
- **The Savior:** Isolated cold backup restored data.



Page A — Ransomware Theory and Case Context

Introduction. The AIIMS New Delhi incident illustrates the serious consequences a cyber incident can have when digital services support healthcare. The original presentation describes disruption to hospital systems and the need to restore services from backups. Healthcare environments are particularly sensitive because staff need timely access to patient records, appointments, laboratory information and administrative systems.

What ransomware is. Ransomware is malicious software or an attack method used to deny access to systems or data, often by encrypting files and demanding payment. Modern incidents may also involve data theft or threats to publish information. Initial access can arise from stolen credentials, exposed remote access, unpatched software or a compromised device. Once inside, attackers may attempt to spread to shared folders and other systems.

Why hospitals are vulnerable. Hospitals operate many interconnected systems, have diverse equipment and must maintain services around the clock. Some devices cannot be updated easily, and clinical teams may rely on older applications. These realities make asset inventories, network separation, tested backups and emergency operating procedures essential.

Key points

- Separate clinical devices, administrative computers, servers and guest networks where practical.
- Use multi-factor authentication for remote access and privileged accounts.
- Patch internet-facing systems quickly and remove unused accounts and services.
- Train staff to report suspicious messages and unexpected login prompts.

Page B — Recovery, Patient Safety and Lessons

Operational and human impact. A hospital cyber incident can delay appointments, interrupt access to electronic records, slow diagnostic workflows and force staff to use paper-based alternatives. The central concern is patient safety as well as data confidentiality. Healthcare organizations need a continuity plan that explains how clinical teams will work if key digital systems become unavailable.

Backup strategy. Backups should be frequent, encrypted where appropriate, access-controlled and isolated from ordinary network accounts. At least one backup copy should be offline or otherwise protected from attackers. Backups must be tested through actual restoration exercises; a backup that cannot be restored is not a dependable recovery plan.

Response and recovery. The response team should isolate affected systems, preserve evidence, identify the scope of compromise and prioritize recovery according to clinical risk. Systems should be checked for persistence and vulnerabilities before reconnecting them. Staff need clear instructions, and patients should receive accurate updates without speculation.

Conclusion. The case demonstrates that cybersecurity is part of healthcare continuity. Strong backups, segmentation, staff preparation and coordinated recovery help reduce downtime and protect patient care.

Key points

- Maintain paper-based downtime procedures for critical clinical workflows.
- Prioritize recovery of systems according to patient-safety impact.
- Practice restoration from isolated backups and document recovery times.
- Review the incident afterward and track corrective actions to completion.


Twitter Headquarters

CASE 03: GLOBAL

TWITTER VIP HIJACK

Using a fabricated IT pretext, attackers convinced employees to hand over credentials to internal administrative tools, allowing them to post from verified celebrity accounts.

- **Crypto Scam:** Posted from Obama, Musk, Gates.
- **Pretexting:** Fake IT call tricked support staff.
- **Admin Tools:** Accessed without user passwords.
- **The Lesson:** Polite phone voices lack proof.

Page A — Social Engineering and Account Takeover

Introduction. The Twitter VIP account hijack case shows how attackers may target people and internal access processes rather than exploit only a software flaw. The presentation describes high-profile accounts being misused to post fraudulent messages. A compromised trusted account can reach a large audience quickly and can make scams appear legitimate.

Social engineering. Social engineering manipulates people into revealing information, approving access or taking an unsafe action. Attackers may impersonate IT staff, create urgency, claim an account problem or use information gathered from public profiles. Pretexting uses a fabricated story; phishing uses deceptive messages or pages; baiting offers something tempting to encourage a risky action.

Why privileged access matters. Support and administration tools may allow staff to reset accounts or change security settings. If access is too broad, poorly monitored or protected by weak verification, one compromised employee account can affect many users. High-impact actions should require strong identity checks and be logged for independent review.

Key points

- Never share passwords, one-time codes or recovery codes with someone who contacts you unexpectedly.
- Verify support requests through a separate, trusted communication channel.
- Use phishing-resistant multi-factor authentication for privileged accounts where available.
- Limit staff permissions to the minimum needed for their role.

Page B — Consequences and Protective Controls

Risks and consequences. Account takeover can lead to fraudulent posts, financial scams, privacy breaches, reputational damage and loss of public trust. People may act quickly because a message appears to come from a public figure or official account. Platforms must therefore treat account security as a safety and trust issue, not merely a user convenience feature.

Preventive controls. Platforms should apply role-based access control, strong authentication, device and session monitoring, approval for sensitive account actions and rate limits on unusual operations. Administrative interfaces should be separated from ordinary workflows, and staff should receive scenario-based social-engineering training.

Detection and response. Alerts should flag unusual access, bulk account changes, unexpected privilege use and suspicious posting patterns. Response teams should revoke active sessions, secure affected accounts, preserve logs, communicate clearly with users and review whether the attacker retained any access. Recovery should include checking email, phone and recovery settings, not just changing a password.

Conclusion. The key lesson is that trusted accounts need strong controls around both people and systems. Verification, least privilege, monitoring and a practiced response process reduce the chance that one compromised workflow becomes a large-scale incident.

Key points

- Require extra verification for account recovery and privileged changes.
- Alert on unusual administrator actions and high-volume account modifications.
- Provide a fast, documented way to revoke sessions and restore legitimate access.
- Educate users to verify surprising financial requests through another channel.

CASE 04: GLOBAL

TARGET CORPORATION

Attackers breached a third-party HVAC vendor via a phishing email, using their legitimate billing login to move laterally across Target's network and infect point-of-sale registers.

- **40M Cards:** Stolen during holiday rush.
- **Vendor Phish:** Small HVAC contractor compromised.
- **Lateral Move:** From billing portal to checkout tills.
- **Ignored Bells:** Security alerts fired but lacked owners.



Page A — Third-Party Access and Retail Security

Introduction. The Target Corporation breach is commonly used to explain the risks created by third-party access and connected retail systems. The presentation emphasizes a compromised access path and security alerts that were not acted on effectively. Retailers hold valuable payment and customer information while also operating large networks of stores, suppliers and service providers.

Third-party risk. Vendors may need access to systems for maintenance, billing, monitoring or other services. If a vendor account is compromised, attackers may use its permissions to enter the organization. The risk grows when vendor access is broad, shared, always enabled or connected to sensitive networks without additional checks.

Network segmentation. Segmentation divides a network into zones and restricts traffic between them. For example, vendor access should not automatically provide a path to payment systems. Firewalls, access gateways and strict allow-lists can limit which systems communicate and which actions are permitted.

Key points

- Give vendors unique accounts with narrowly defined permissions and expiry dates.
- Require multi-factor authentication and monitored remote-access gateways.
- Separate payment environments from general business and vendor networks.
- Review vendor access whenever contracts, personnel or responsibilities change.

Page B — Monitoring, Response and Lessons

Security monitoring. Detection tools generate alerts when behavior resembles an attack, but alerts only help when someone investigates them. Organizations need clear alert ownership, severity levels, escalation rules and response deadlines. High-risk events should be reviewed by trained personnel and correlated with activity from identity, endpoint and network systems.

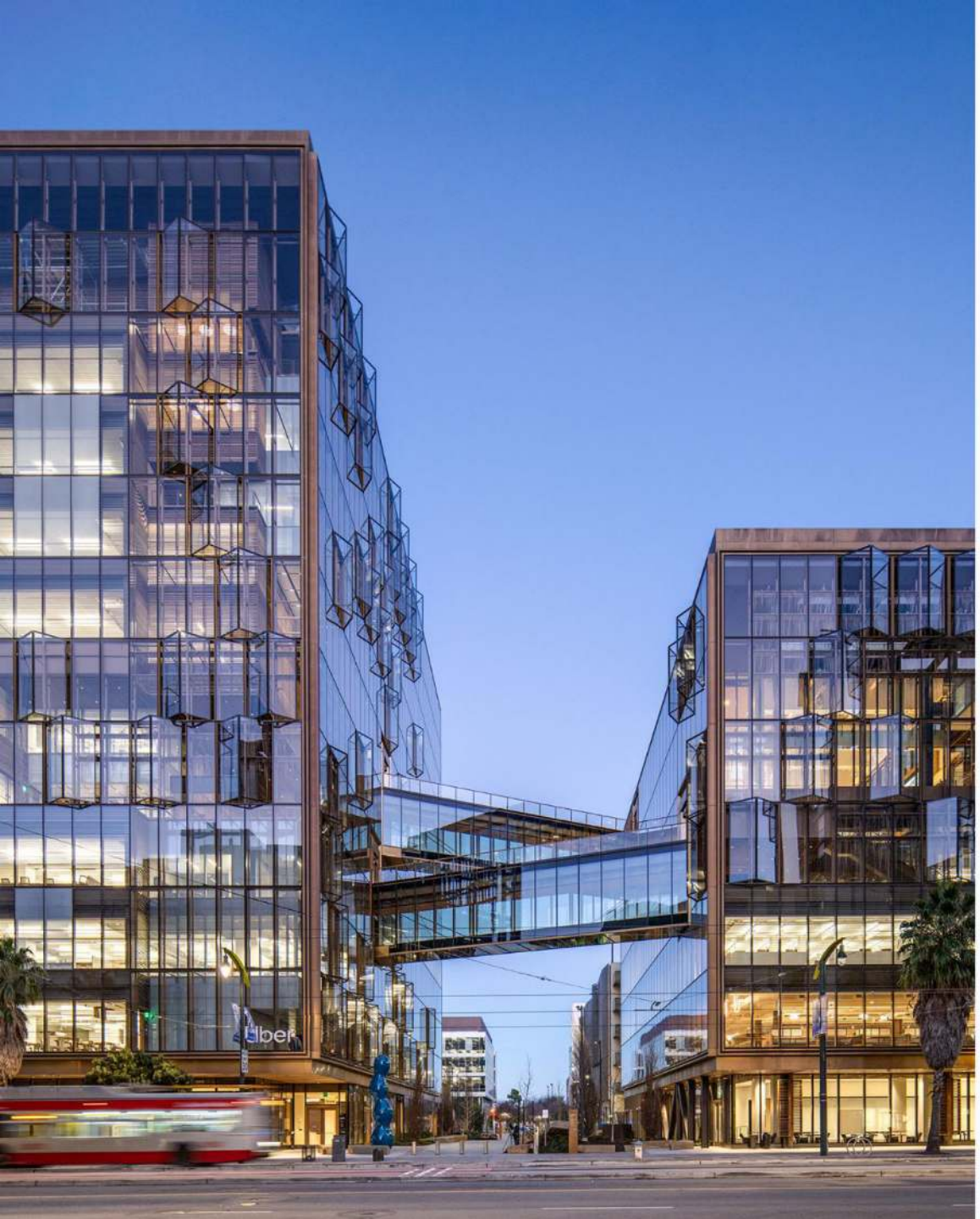
Protecting payment data. Retail organizations should minimize the amount of sensitive data they store, protect it in transit and at rest, and restrict access to payment environments. Payment terminals and supporting systems should be hardened, regularly assessed and monitored for unexpected software or network activity. Compliance standards can support security, but compliance alone does not guarantee that every attack will be prevented.

Incident response. Once a breach is suspected, teams should contain compromised accounts and devices, investigate how access occurred, preserve evidence, assess what information may have been affected and coordinate communications with partners and relevant authorities. Remediation should include closing the initial access route and testing whether the attacker can return.

Conclusion. The case highlights that third-party access must be treated as part of the organization’s security boundary. Segmentation, least privilege and effective alert handling can significantly reduce the impact of a compromise.

Key points

- Assign every critical alert to a named team and track it until closure.
- Test whether detection alerts lead to timely investigation and containment.
- Reduce stored payment data and protect systems that process it.
- Assess vendor security and revoke access that is no longer required.



CASE 05: GLOBAL

UBER BREACH

An attacker utilized 'MFA fatigue,' repeatedly bombing a contractor's phone with login approval prompts until the frustrated user finally accepted, granting full internal access.

- **MFA Fatigue:** Push-bombing defeated two-factor.
- **The Tired Yes:** Contractor approved rogue login.
- **Internal Reach:** Slack and code repositories exposed.
- **The Fix:** Denied prompts must trigger account lock.

Page A — Credential Abuse and Multi-Factor Authentication

Introduction. The Uber breach example in the presentation highlights how a compromised account and approval fatigue can contribute to unauthorized access. Modern organizations rely on cloud dashboards, collaboration platforms and administrative tools, so one identity can sometimes open doors to many connected services.

Credential compromise. Credentials can be stolen through phishing, reused passwords, malware or unsafe storage. Attackers may then try the same password on other services or exploit a logged-in session. Multi-factor authentication (MFA) adds another proof of identity, but its effectiveness depends on the method and how approval requests are handled.

MFA fatigue. In an MFA-fatigue attack, an attacker repeatedly triggers login approval prompts, hoping the legitimate user will approve one to stop the interruptions. Users should reject unexpected prompts and report them. Number matching, phishing-resistant security keys and risk-based controls can make this approach harder to use.

Key points

- Use unique passwords stored in a reputable password manager.
- Never approve an authentication prompt you did not initiate.
- Prefer phishing-resistant MFA for administrators and high-risk services.
- Store secrets in approved secret-management systems rather than chats or code.

Page B — Least Privilege and Incident Lessons

Least privilege. Every account should have only the permissions needed for its work. Administrative access should be separate from everyday accounts, granted for limited periods when possible and reviewed regularly. Cloud environments should use centralized identity controls, strong logging and alerts for unusual access or privilege escalation.

Secrets and internal tools. API keys, tokens and passwords can provide direct access to systems. They should be rotated if exposed, scoped to specific tasks and stored securely. Sensitive internal tools should not be accessible simply because a user has gained access to one employee account. Organizations should also review access to code repositories, cloud consoles and communication platforms.

Response steps. When an account compromise is suspected, security teams should revoke sessions and tokens, reset affected credentials, investigate login history, identify systems accessed and check for persistence. They should preserve relevant evidence and communicate through verified channels. After recovery, the organization should determine how access was obtained and improve the controls that failed.

Conclusion. This case reinforces that authentication is only one layer of defense. Least privilege, secure secret handling, monitoring and user training work together to limit the damage caused by compromised credentials.

Key points

- Review administrator and vendor permissions at regular intervals.
- Revoke sessions and rotate exposed tokens during incident response.
- Alert on unusual login locations, devices, time patterns and privilege changes.
- Use short, clear procedures for reporting unexpected MFA prompts.

WHAT A TIRED TUESDAY CAN CATCH

01. CALL BACK

Verify phone requests directly.

02. SEGMENT ACCESS

Isolate vendor network accounts.

03. UPGRADE MFA

Hardware keys beat yes/no buzzes.

04. OWN ALERTS

Assign owners to security bells.



THE HUMAN ELEMENT

Security depends equally on strong technology and unyielding human judgment.

QUESTIONS & DISCUSSION

IMAGE SOURCES



https://aiims.edu/images/com_fwgallery/files/806/main-building.JPG

Source: aiims.edu



https://upload.wikimedia.org/wikipedia/commons/6/60/Twitter_Offices_in_San_Francisco.jpg?utm_source=en.wikipedia.org&utm_campaign=index&utm_content=original

Source: en.wikipedia.org



https://thumbs.dreamstime.com/b/target-retail-bullseye-logo-bloomington-mn-usa-april-store-exterior-trademark-178926701.jpg

Source: www.dreamstime.com



http://www.aiany.org/wp-content/uploads/2023/01/AIANY-Design-Awards-Uber-Headquarters-Shop-Architects-Photo-Jason-ORear-03.jpg

Source: www.aiany.org